

Responder NTLMv2 Capture Evidence Report

Internal Network & Active Directory Pentest Evidence Documentation

Field	Details
Test Area	Responder NTLMv2 capture
Evidence Source	10-responder-ntlmv2-hash-captured.png
Result Type	Credential material captured in lab
Primary Tool / Component	Responder
MITRE ATT&CK Mapping	T1557.001 - LLMNR/NBT-NS Poisoning and SMB credential capture
Document Purpose	Professional GitHub-ready evidence report with redacted screenshot and interpretation.

This report documents one specific evidence row from the AD Network assessment. It is intentionally evidence-specific, not a generic attack tutorial. Sensitive values have been blurred or represented as redacted placeholders for safe portfolio publication.

1. Embedded Evidence Screenshot

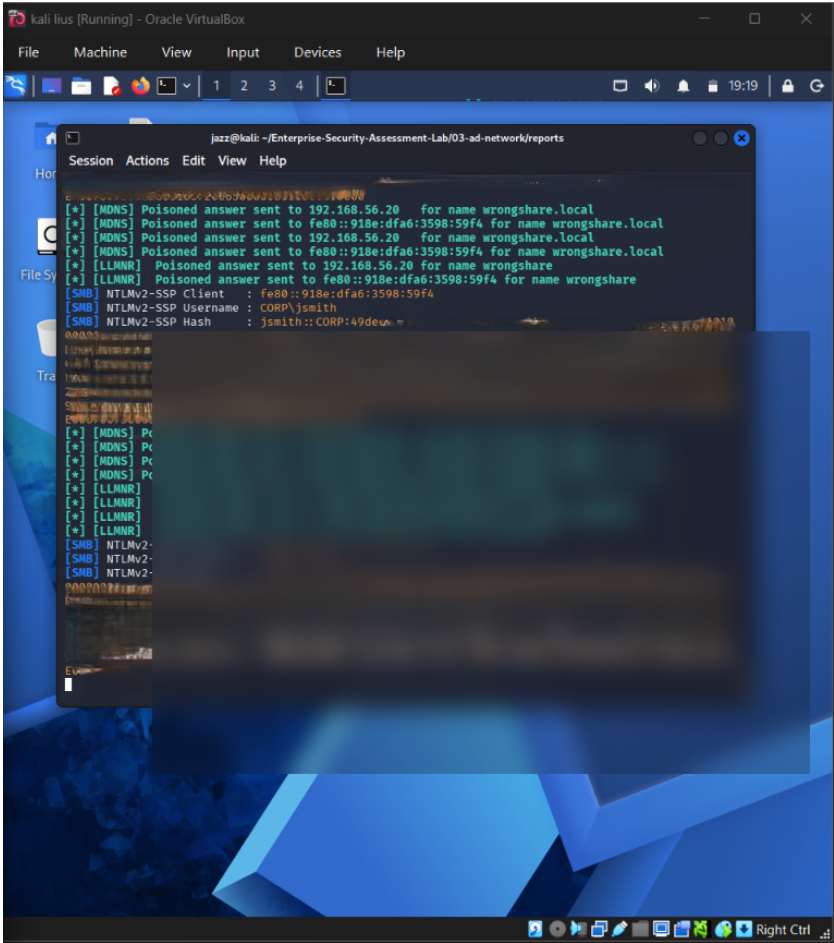


Figure 1 - Redacted evidence screenshot: 10-responder-ntlmv2-hash-captured.png

What this screenshot proves

The screenshot shows Responder running on Kali and capturing NTLMv2-style authentication material. The sensitive hash material is blurred in the embedded evidence image.

Evidence Context

Area	Value
Testing Phase	Credential Interception / Internal Network Attack Simulation
Tool / Component	Responder
Objective	Demonstrate how broadcast name resolution abuse can capture NTLMv2 authentication material from a Windows domain endpoint in an isolated lab.
Result Type	Credential material captured in lab

2. Evidence-Specific Methodology

This section explains how this evidence fits into the overall internal network and Active Directory attack path. The goal is to demonstrate professional testing logic, not simply show a terminal screenshot.

- Identify the Kali interface connected to the AD lab network.
- Start Responder on the lab interface in verbose mode.
- Trigger name-resolution traffic from a Windows domain endpoint.
- Capture NTLMv2 authentication material and save evidence with sensitive values redacted.

Command / Workflow Used

```
ip addr
sudo responder -I <LAB_INTERFACE> -dwPv
# Trigger from Windows lab endpoint: \nonexistent-share\test
```

Sanitized Output Style

```
[SMB] NTLMv2-SSP Client    : <REDACTED_ENDPOINT_IP>
[SMB] NTLMv2-SSP Username  : CORP\<REDACTED_USER>
[SMB] NTLMv2-SSP Hash      : <REDACTED_NETNTLMV2_HASH>
```

Assessment Interpretation

The evidence supports the result type: Credential material captured in lab. In a professional assessment, this evidence would be paired with the exact testing scope, timestamps, target identifiers, and remediation ownership. For GitHub publication, the report intentionally avoids showing live secrets, passwords, hashes, or reusable credential material.

3. Risk Analysis

If this existed in a real enterprise network, a low-privileged attacker on the internal network could capture reusable credential material. If passwords are weak, the hash can be cracked offline and used for further enumeration or lateral movement.

Why this matters in enterprise AD environments

- Active Directory attacks often chain multiple medium-risk issues into domain compromise.
- Credential material, even when not plaintext, can become dangerous if cracking, relaying, or alternate authentication is possible.
- Graph-based permissions and relationship analysis is necessary because AD risk is often hidden in group nesting and delegated rights.
- Evidence must be documented clearly so defenders can connect the technical finding to a specific control gap.

Recommended Remediation

- Disable LLMNR and NBT-NS where operationally possible.
- Enforce SMB signing to reduce relay risk.
- Use long passphrases and block common passwords.
- Monitor suspicious name-resolution and Responder-like traffic.
- Segment internal networks and limit workstation-to-workstation authentication.

Detection and Monitoring Opportunities

- Correlate authentication events with unusual source hosts and off-hours activity.
- Monitor SMB, LDAP, Kerberos, and replication-related event patterns.
- Alert on abnormal use of administrative protocols and credential dumping indicators.
- Review domain privilege assignments and privileged group membership changes regularly.

4. GitHub Publication and Redaction Guidance

This report is prepared for safe GitHub portfolio publication. The embedded screenshot has been treated as evidence, but sensitive material must not be recoverable or readable.

Sensitive Item	Action for GitHub
NTLM / NetNTLMv2 hashes	Blur or remove completely. Never publish reusable hash material.
Kerberos TGS / krb5tgs values	Blur or replace with <REDACTED_TICKET>.
Plaintext passwords	Do not publish. Replace with <REDACTED_PASSWORD>.
DCSync / NTDS hashes	Treat as domain compromise material and fully redact.
Internal IPs / domain names	May remain for lab context, but redact if privacy is required.
Username / service accounts	Keep only if lab-only; otherwise redact or generalize.

Suggested GitHub Link

[Open Report](./reports/evidence/01-responder-ntlmv2-capture-evidence-report.pdf)

Professional Note

This document should be stored with the AD Network module reports, preferably under 03-ad-network/reports/evidence/. It is designed to replace a plain screenshot filename in the Evidence-Based Testing Summary table with a professional clickable report.